TEK 1314 - KEAMANAN SIBER

HOME ABOUT CONTENT OTHERS

# SOC Engagement

# Mengamankan Infrastruktur Backend EduRover



**Lead**

NURKHOLIFAH
(J0404241055)

**Blue Team**

MUHAMMAD ZEINAL HAQ
(J0404241108)

**Red Team**

MUHAMMAD RIFQI FADHILAH
(J0404241013)

# Robot Car Mission

# Edurover

EduRover merupakan platform robot edukasi modular berbasis ESP32-S3 yang terintegrasi dengan sistem web kompetisi untuk mendukung pembelajaran dan perlombaan pada jenjang SD hingga SMA. Robot ini membaca berbagai sensor, seperti tujuh sensor inframerah TCRT5000, sensor warna RGB TCS34725, dan encoder motor, lalu mengirimkan data telemetri checkpoint ke server pusat melalui HTTP POST yang diautentikasi menggunakan header X-API-KEY. Website kompetisi sendiri digunakan untuk registrasi tim, pemantauan pertandingan, penilaian oleh juri, dan penyajian leaderboard secara real-time.



Pada tugas SOC Engagement ini, fokus perlindungan berada pada infrastruktur backend, yaitu server API, database, dan dashboard yang menerima data dari robot serta menyajikan hasil kompetisi. Infrastruktur ini menyimpan data peserta, menerima input dari banyak klien melalui API Key, dan menentukan hasil resmi kompetisi, sehingga integritas dan ketersediaannya menjadi hal yang kritis untuk dijaga.

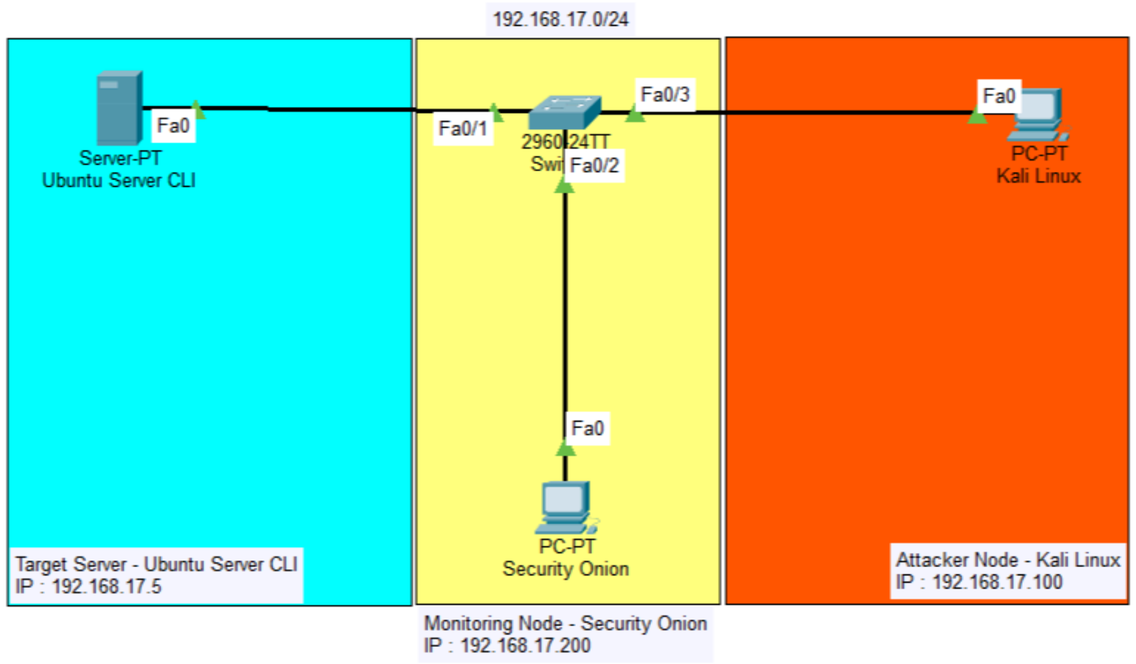
# Deklarasi Tech Stack & Replikasi

| Komponen | Teknologi pada Proyek IoT Asli | Direplikasi sebagai (Target Node) |
|---|---|---|
| **Sistem Operasi Backend** | Linux pada laptop server lokal; aplikasi Laravel/PHP | Ubuntu Server 22.04 LTS (VM VirtualBox) + Nginx Web Server host |
| **Database/Penyimpanan Data** | MySQL pada server lokal | MySQL 8.0 dalam Docker Container (appnet, port 3306 terisolasi) |
| **Protokol Komunikasi Sensor** | HTTP REST melalui Wi-Fi lokal; ESP32-S3 mengirim data ke endpoint API. API key dikirim melalui header | HTTP REST API (/api/v1/checkpoint) & Mosquitto MQTT pada jaringan lab terisolasi (192.168.17.0/24) |
| **Dashboard/Monitoring** | Aplikasi web Laravel; leaderboard realtime melalui Laravel Reverb/WebSocket, dengan polling sebagai cadangan | Web Container (nginx:alpine di loopback 127.0.0.1:8080) diakses via browser jaringan lab |



Next Slide

# ARSITEKTUR SIMULASI




# SKEMA IP

| Node Simulasi | Interface / IP Address | Role & Implementasi Teknis |
|---|---|---|
| **Target Node (Ubuntu)** | 192.168.17.5 | Host Nginx, Docker (Laravel & MySQL), & Elastic Agent. |
| **Attacker Node (Kali Linux)** | 192.168.17.100 | Platform Red Team (recon, pengujian API, & serangan). |
| **Monitoring Node (SO Mgmt)** | 192.168.17.200 | Dashboard SOC & Manajemen Security Onion. |
| **Monitoring Node (Sniffer)** | Promiscuous (No IP) | Interface SPAN untuk penangkapan paket jaringan. |

# PROGRES HARDENING

| Kategori Kontrol | Kontrol Hardening | Status |
|---|---|---|
| A. Access & Auth | Nonaktifkan SSH Password Auth (PasswordAuthentication no) & wajibkan Key Auth | Sudah |
| | Nonaktifkan PermitRootLogin di SSH | Sudah |
| B. Service & Surface | Firewall UFW Whitelist (Hanya port 22, 80, 443, 1883) | Sudah |
| | Sembunyikan versi Nginx Server (server_tokens off) | Sudah |
| | Nginx Rate Limiting pada Endpoint API REST (/api/v1/) | Belum |
| C. Data & App | Isolasi Total Port 3306 MySQL (Docker appnet Internal Only) | Sudah |
| | Amankan Kredensial Database via File .env (chmod 600) | Sudah |
| | Force Redirect HTTP ke HTTPS (301) + Header HSTS | Sudah |

# Attack Plan 🔒

## Fase 2

| Skenario Serangan | Kategori Teknik | Tools Utama | Target & Tujuan Eksekusi |
|---|---|---|---|
| Reconnaissance | Reconnaissance | Nmap, Gobuster | Scanning port terbuka (22, 80, 443, 1883) & pemindaian direktori tersembunyi (.env). |
| SSH Brute-Force | Exploitation | Hydra | Menguji kekuatan kredensial SSH pada konfigurasi lemah Fase 1. |
| API Key Spoofing | Web / API IoT | Burp Suite, cURL | Mengirim data pencapaian (checkpoint) palsu tanpa X-API-KEY valid untuk manipulasi skor. |

# Kendala Pembelajaran

**Konsumsi Sumber Daya VM (Spesifikasi Laptop Limit):**

- Hambatan: Menjalankan 3 VM sekaligus (Security Onion, Kali Linux, Ubuntu Target) membuat penggunaan RAM dan CPU laptop sangat tinggi (lagging / overload).
- Solusi: Mengatur alokasi RAM secara efisien pada VirtualBox dan mengoptimalkan penggunaan CLI (Headless Mode) pada Target Node untuk menghemat memori.

**Kompleksitas Penginstalan & Konfigurasi Security Onion:**

- Hambatan: Proses instalasi Security Onion membutuhkan waktu lama serta sering gagal saat alokasi resource minimal atau saat pendaftaran interface sniffer SPAN.
- Solusi: Melakukan penyesuaian batas minimal alokasi virtual disk/RAM dan memastikan konfigurasi Promiscuous Mode di VirtualBox diset ke Allow All sebelum proses setup dilanjutkan.

# TERIMA

# KASIH

